

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

UNC4466 Attack Campaign Targets Veritas Backup Exec and Deploys ALPHV Ransomware

Date of Publication

April 10, 2023

Admiralty Code

A1

TA Number

TA2023175

Summary

Attack began: October 2022

Threat Actor: UNC4466

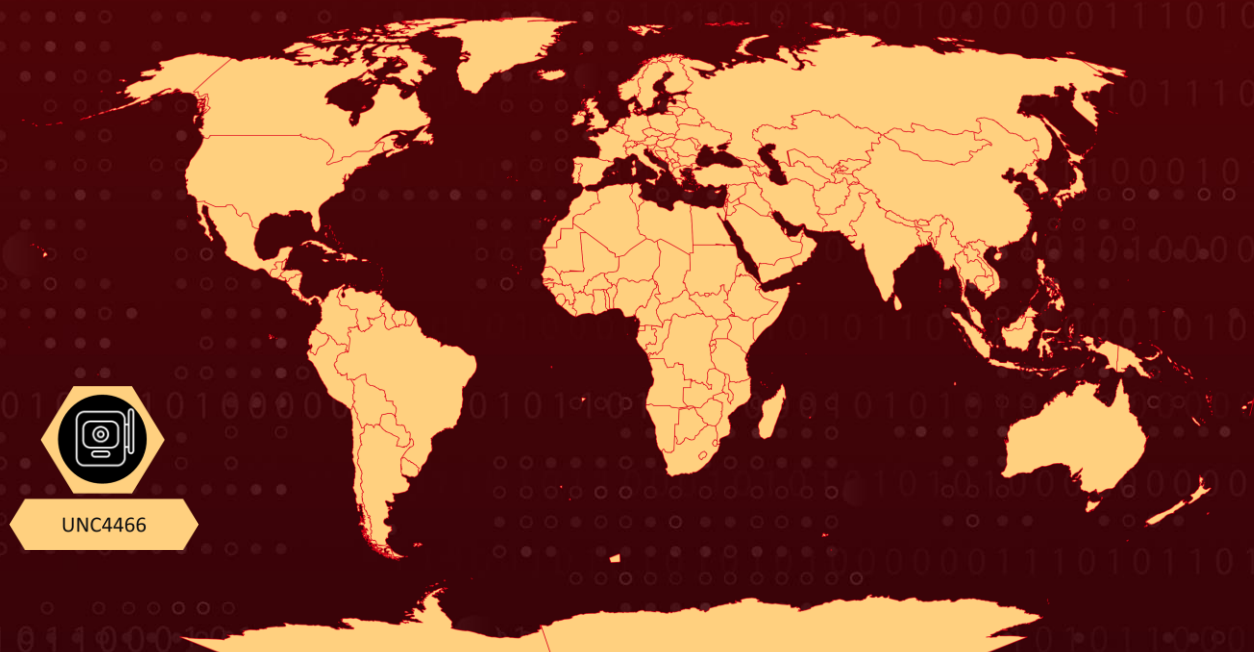
Affected Product: Veritas Backup Exec

Malware: BlackCat (aka ALPHV and Noberus) ransomware

Attack Region: Worldwide

Attack: UNC4466 conducted an attack campaign in late 2022, gaining initial access to an internet-exposed Windows server running Veritas Backup Exec and using various techniques to escalate privileges, evade detection, and deploy the ALPHV ransomware, with over 8,500 potentially vulnerable IP addresses identified.

🗡️ Attack Regions



Powered by Bing

© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

CVE	NAME	AFFECTED PRODUCT	ZERO-DAY	CISA KEV	PATCH
CVE-2021-27876	Veritas Backup Exec Agent File Access Vulnerability	Veritas Backup Exec			
CVE-2021-27877	Veritas Backup Exec Agent Improper Authentication Vulnerability	Veritas Backup Exec			
CVE-2021-27878	Veritas Backup Exec Agent Command Execution Vulnerability	Veritas Backup Exec			

Attack Details

#1

UNC4466 is a threat actor that conducted an attack campaign in late 2022, gaining initial access to an internet-exposed Windows server running Veritas Backup Exec version 21.0 using the Metasploit module. The attacker then used internal reconnaissance tools like Famatech's Advanced IP Scanner and ADRecon to gather network, account, and host information in the victim's environment. UNC4466 used BITS to download additional tools such as LAZAGNE, LIGOLO, WINSW, RCLONE, and the ALPHV ransomware encryptor. The attacker also leveraged SOCKS5 tunneling to communicate with compromised systems in the victim network and used multiple credential access tools like Mimikatz, LaZagne, and Nanodump to escalate privileges and gather clear-text credentials and credential material.

#2

UNC4466 took steps to evade detection, including clearing event logs and using the Set-MpPreference cmdlet to disable Microsoft Defender's real-time monitoring capability. Finally, UNC4466 deployed the Rust-based ALPHV ransomware, adding immediate tasks to the default domain policy to disable security software, download the ALPHV encryptor, and execute it. Over 8,500 IP addresses were found advertising the "Symantec/Veritas Backup Exec ndmp" service on the default port 10000 and port 9000 and port 10001, indicating the prevalence of internet-exposed instances that could potentially be probed by attackers.

Recommendations



Patch and harden the Veritas Backup Exec server, including disabling unnecessary services, restricting access to critical files and directories, and using strong passwords.



Block incoming traffic to TCP ports 10000, 9000, and 10001. These ports are associated with the Symantec/Veritas Backup Exec ndmp service and may be used by attackers to gain initial access to vulnerable systems.



Monitor internet-facing systems for unauthorized access attempts and suspicious activity, including the use of the Metasploit module 'exploit/multi/veritas/beagent_sha_auth_rce'.



Block the related indicators or monitor the download and use of tools like Advanced IP Scanner, ADRecon, LAZAGNE, LIGOLO, WINSW, RCLONE, and ALPHV ransomware, especially from untrusted sources.



Implement strict controls on the use of Background Intelligent Transfer Service (BITS) and SOCKS5 tunneling, including blocking their use entirely or monitoring their use for suspicious activity.



Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0007</u> Discovery	<u>TA0008</u> Lateral Movement	<u>TA0009</u> Collection
<u>TA0011</u> Command and Control	<u>TA0040</u> Impact	<u>T1486</u> Data Encrypted for Impact	<u>T1489</u> Service Stop
<u>T1490</u> Inhibit System Recovery	<u>T1529</u> System Shutdown/Reboot	<u>T1047</u> Windows Management Instrumentation	<u>T1053</u> Scheduled Task/Job
<u>T1053.005</u> Scheduled Task	<u>T1059</u> Command and Scripting Interpreter	<u>T1059.001</u> PowerShell	<u>T1059.006</u> Python
<u>T1569</u> System Services	<u>T1569.002</u> Service Execution	<u>T1027</u> Obfuscated Files or Information	<u>T1027.002</u> Software Packing
<u>T1027.009</u> Embedded Payloads	<u>T1055</u> Process Injection	<u>T1070</u> Indicator Removal	<u>T1070.001</u> Clear Windows Event Logs

<u>T1070.004</u> File Deletion	<u>T1112</u> Modify Registry	<u>T1134</u> Access Token Manipulation	<u>T1134.001</u> Token Impersonation/Theft
<u>T1222</u> File and Directory Permissions Modification	<u>T1497</u> Virtualization/Sandbox Evasion	<u>T1497.001</u> System Checks	<u>T1548</u> Abuse Elevation Control Mechanism
<u>T1548.002</u> Bypass User Account Control	<u>T1562</u> Impair Defenses	<u>T1562.001</u> Disable or Modify Tools	<u>T1564</u> Hide Artifacts
<u>T1564.010</u> Process Argument Spoofing	<u>T1574</u> Hijack Execution Flow	<u>T1574.011</u> Services Registry Permissions Weakness	<u>T1620</u> Reflective Code Loading
<u>T1622</u> Debugger Evasion	<u>T1484</u> Domain Policy Modification	<u>T1484.001</u> Group Policy Modification	<u>T1007</u> System Service Discovery
<u>T1012</u> Query Registry	<u>T1016</u> System Network Configuration Discovery	<u>T1033</u> System Owner/User Discovery	<u>T1057</u> Process Discovery
<u>T1082</u> System Information Discovery	<u>T1083</u> File and Directory Discovery	<u>T1087</u> Account Discovery	<u>T1135</u> Network Share Discovery
<u>T1543</u> Create or Modify System Process	<u>T1543.003</u> Windows Service	<u>T1547</u> Boot or Logon Autostart Execution	<u>T1547.001</u> Registry Run Keys / Startup Folder
<u>T1095</u> Non-Application Layer Protocol	<u>T1105</u> Ingress Tool Transfer	<u>T1021</u> Remote Services	<u>T1021.001</u> Remote Desktop Protocol
<u>T1213</u> Data from Information Repositories	<u>T1583</u> Acquire Infrastructure	<u>T1583.003</u> Virtual Private Server	

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
IPV4	45[.]61[.]138[.]109 185[.]141[.]62[.]123 5[.]199[.]169[.]209
URL	hxxp://185[.]141[.]62[.]123:10228/update[.]exe

TYPE	VALUE
MD5	da202cc4b3679fdb47003d603a93c90d 5fe66b2835511f9d4d3703b6c639b866 1f437347917f0a4ced71fb7df53b1a05 b41dc7bef82ef384bc884973f3d0e8ca c590a84b8c72cf18f35ae166f815c9df 24b0f58f014bd259b57f346fb5aed2ea e31270e4a6f215f45abad65916da9db4 4fdabe571b66ceec3448939bfb3ffcd1 68d3bf2c363144ec6874ab360fdda00a ee6e0cb1b3b7601696e9a05ce66e7f37 f66e1d717b54b95cf32154b770e10ba4 17424a22f01b7b996810ba1274f7b8e9
IPV4:PORT	45[.]61[.]138[.]109:45815 45[.]61[.]138[.]109:43937 45[.]61[.]138[.]109:36931 5[.]199[.]169[.]209:31600 45[.]61[.]138[.]109:41703 185[.]99[.]135[.]115:39839 185[.]99[.]135[.]115:41773 45[.]61[.]138[.]109:33971 185[.]141[.]62[.]123:50810 185[.]99[.]135[.]115:49196

Patch Link

https://www.veritas.com/support/en_US/security/VTS21-001

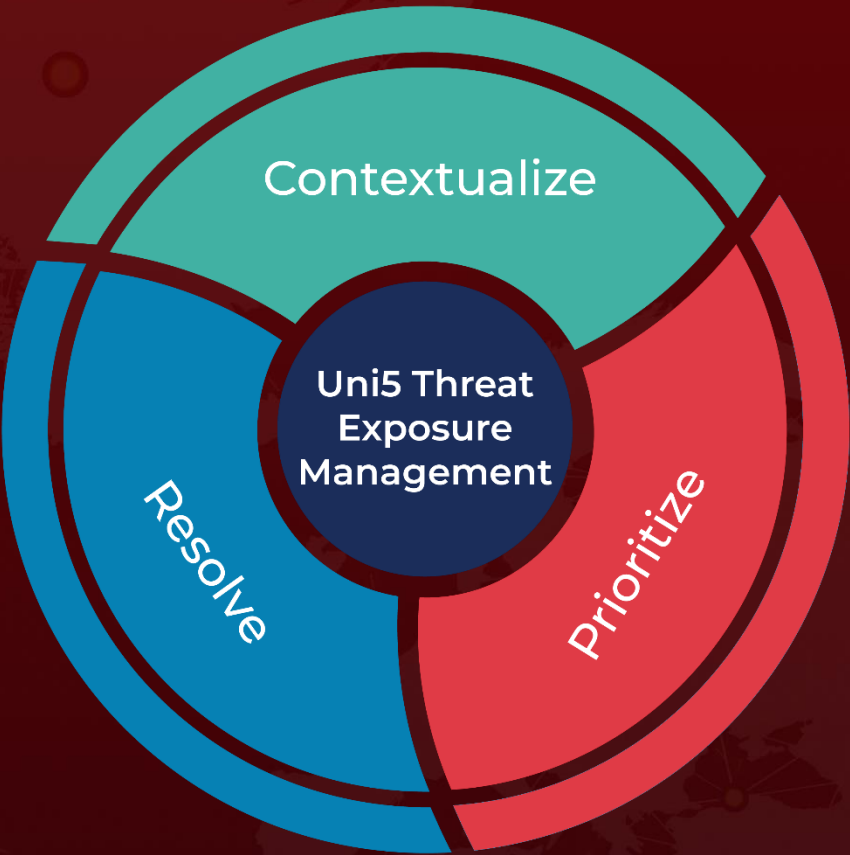
References

<https://www.mandiant.com/resources/blog/alphv-ransomware-backup>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
April 10, 2023 • 5:00 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com